

TD1 CH4

1. Contexte de la mission.....	2
2. Préparation de l'environnement de test (Windows 10)....	2
3. Réalisation des tests d'intrusion (Kali Linux).....	2
A. Tests avec l'outil "John the Ripper"	2
B. Tests avec l'outil "Ophcrack"	3

1. Contexte de la mission

À la demande de M. Brillat, nous avons réalisé un audit visant à vérifier l'efficacité de la sensibilisation des utilisateurs aux risques de sécurité. L'objectif est de réaliser des tests d'usurpation sur trois profils types pour éprouver la solidité de leurs mots de passe.

2. Préparation de l'environnement de test (Windows 10)

Avant de lancer les attaques, nous avons configuré une machine virtuelle Windows 10 pour simuler l'environnement cible.

Création des utilisateurs cibles : Conformément au guide de configuration, trois comptes ont été créés dans le groupe Administrateurs avec des niveaux de complexité variables :

- Compte ENEDIS : Configuré avec un mot de passe faible (moins de 8 caractères alphanumériques). *Exemple utilisé : judo63.*
- Compte MSA : Configuré avec un mot de passe moyen (plus de 8 caractères alphanumériques). *Exemple utilisé : aurillac15.*
- Compte CLIC : Configuré avec un mot de passe fort et complexe (choix libre). *Exemple utilisé : P@ssw0rd-Secur!te.*

Extraction des empreintes (Hashs) : Pour récupérer les données d'authentification (qui ne sont pas stockées en clair), nous avons utilisé l'outil FGDUMP en tant qu'administrateur.

- Cela a permis d'extraire le contenu des fichiers SYSTEM et SAM.
- Le résultat a été enregistré dans le fichier 127.0.0.1.pwdump.
- Le fichier a été nettoyé via Notepad++ pour ne conserver que les lignes concernant nos trois cibles.

3. Réalisation des tests d'intrusion (Kali Linux)

Nous avons redémarré la machine sur la distribution Kali Linux pour effectuer l'analyse. Après avoir configuré le clavier (setxkbmap fr) et localisé la partition Windows (fdisk -l), nous avons accédé au fichier .pwdump extrait précédemment.

A. Tests avec l'outil "John the Ripper"

Nous avons testé trois modes d'attaque documentés dans le support technique :

1. Attaque en mode "Single" (Contextuelle)

- Commande : `john --single /chemin/fichier.pwdump`
- Analyse : Ce mode tente de deviner le mot de passe en utilisant les informations du compte (nom d'utilisateur "ENEDIS", "MSA") et en appliquant des transformations simples (ajout de chiffres, inversions).
- Résultat : Le mot de passe du compte ENEDIS a été trouvé quasi instantanément car il était trop simple et court.

2. Attaque par Dictionnaire (Wordlist)

- Commande : `john --wordlist=/usr/share/wordlists/rockyou.txt /chemin/fichier.pwdump`
- Analyse : Nous avons utilisé le dictionnaire rockyou.txt (décompressé via gunzip) qui contient une liste massive de mots de passe communs.
- Résultat : Le mot de passe du compte MSA (aurillac15) a été compromis. Bien qu'il dépasse 8 caractères, il est composé d'un mot commun et d'une suite de chiffres prévisibles présents dans le dictionnaire.

3. Attaque par Force Brute (Incremental)

- Commande : `john --incremental /chemin/fichier.pwdump`
- Analyse : Ce mode teste absolument toutes les combinaisons de caractères possibles.
- Résultat : Sur le temps imparti au TP, le mot de passe du compte CLIC n'a pas été trouvé. La complexité (mélange de caractères) rend le temps de calcul exponentiel et irréaliste pour une attaque rapide.

B. Tests avec l'outil "Ophcrack"

Dans une seconde phase, nous avons utilisé Ophcrack, un outil basé sur les Rainbow Tables (tables arc-en-ciel).

- Procédure : Chargement du fichier PWDUMP et utilisation de la table vista_proba_free.
- Observation : Contrairement à la force brute qui "calcule", Ophcrack "cherche" dans une base de données pré-calculée.
- Résultat : L'outil a retrouvé les mots de passe alphanumériques (ENEDIS et MSA) extrêmement rapidement (quelques secondes), démontrant que la longueur seule ne suffit pas face aux Rainbow Tables si le mot de passe reste alphanumérique standard.